



Phase 5

Mobile Application Testing

Executive Summary

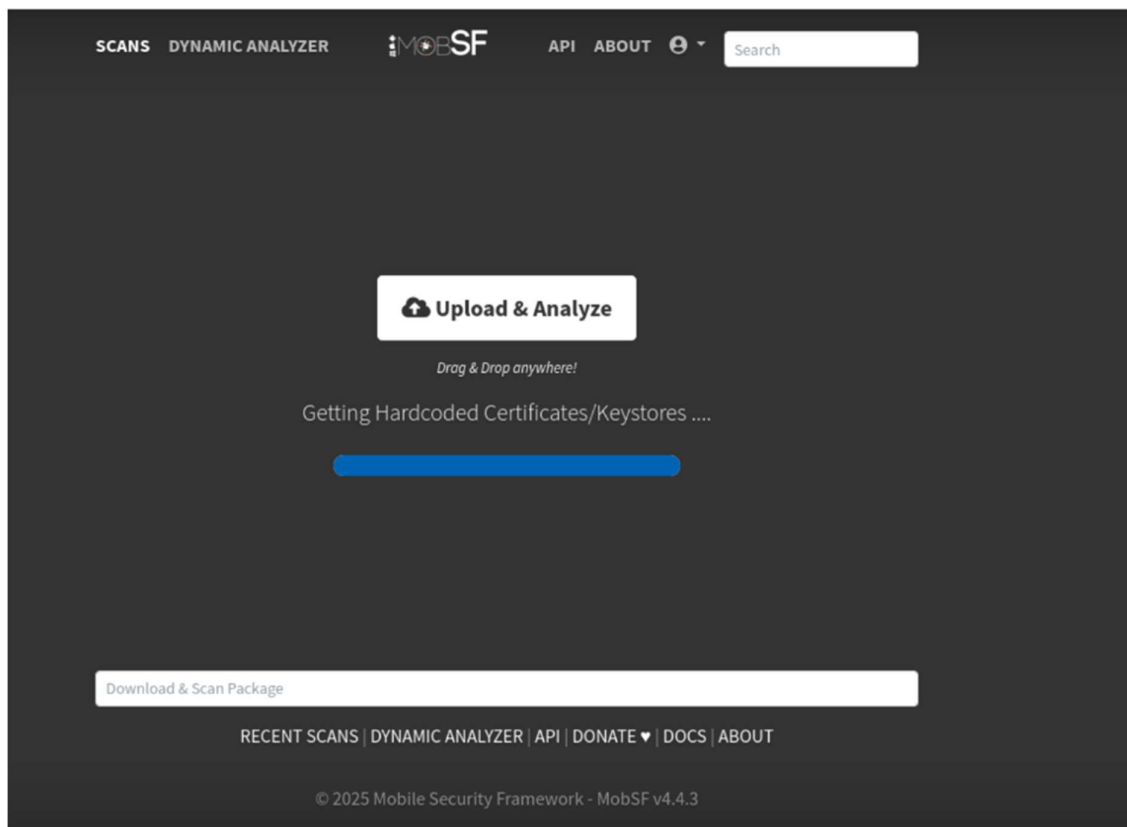
The testing of Damn vulnerable Bank (DVBA) application was conducted to reveal vulnerabilities such as insecure data storage, clear text communication, sensitive information logging and excessive permissions. These issues pose threat to privacy of end user and they may end up to data theft and data exfiltration. MobSF analysis scoring tells the overall security posture and violations of several OWASP top 10 mobile controls

Tools used

- Mobile Security Framework (MobSF)
- Frida
- Drozer
- Android Emulator

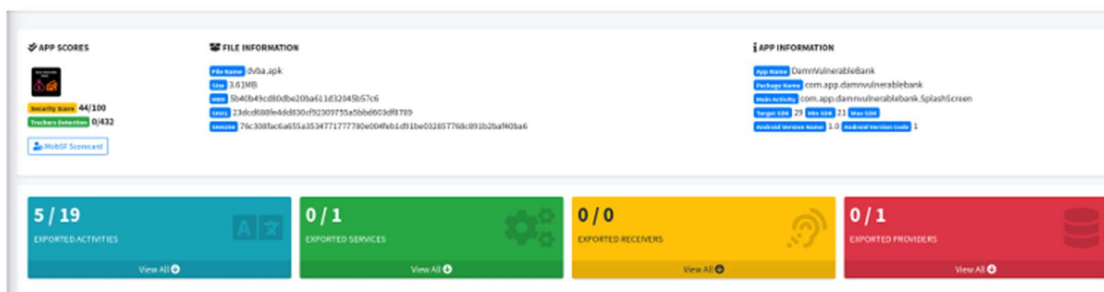
Static Analysis with MobSF

We will upload the apk to the MobSF for automation of static analysis, which will inspect applications code, its demanding permissions network settings and storage behavior.



Security Score Overview

The MobSF Security Scoring results lot of vulnerabilities with weak security posture for Damn vulnerable Bank app.



The Overall security score was 44/100. The analysis highlights misconfigurations which expose the app and device to high impact threats. The resistance score is low which tells us that the apps reverse engineering mechanisms are weak.



Findings

The following Table shows the vulnerabilities identified during the static analysis of DVBA apk using MobSF Framework.

Critical Vulnerabilities Findings

Test ID	Vulnerability	Severity	Target App	CVSS
001	Insecure Storage (External Storage R/W)	High	dvba.apk	7.5
002	Cleartext Traffic Enabled	High	dvba.apk	7.1
003	Backup Enabled	Medium	dvba.apk	6.5
004	Logging Sensitive Information	Medium	dvba.apk	6.0

This Static analysis reveals High severity issues particularly insecure storage process and use of clear text communication. Both of these vulnerabilities expose user data under unauthorized access. Further Medium vulnerabilities such as unrestricted Back up facilities and logging sensitive information poses threat to the privacy of the end use which may result in data theft and data exfiltration.

Key Issues Identified:

- Insecure Data Storage: App can read/write to External Storage
- Lack of Encryption: Cleartext HTTP traffic enabled
- Data Exposure: Backup allowed via ADB
- Information Leakage: Sensitive data logged



Vulnerability Logging

Test ID	Vulnerability	Severity	Target App
001	Insecure Storage (External Storage R/W)	High	dvba.apk
002	Cleartext Traffic Enabled	High	dvba.apk
003	Backup Enabled	Medium	dvba.apk
004	Logging Sensitive Information	Medium	dvba.apk

Summary

The Static analysis of the DVBA Apk with MobSF resulted in a weak secured posture meaning it had very high to medium impact vulnerabilities. Insecure storage, Unencrypted traffic, Unauthorized backups, Secretive loggings which all point to an very weakly designed application with lot of loopholes. The app lacks essentials protections which significantly increases attack surface putting end user at risk.